FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

MK FRAUD INSIGHTS

ESSENTIAL FRAUD READINESS REPORT

22 of the organisation's 43 first-priority fraud schemes remain open, most of them in procurement and third parties and people and payroll, and 1 control reported in place is not supported in practice.

55.5 / 100 **DEVELOPING**

PREPARED FOR

Fictional Retail Group (mixed controls)

Assessment reference · FX-P3

Assessment date · 11 November 2026

CONFIDENTIAL · PREPARED FOR THE MANAGEMENT OF FICTIONAL RETAIL GROUP (MIXED CONTROLS)

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

WHAT DOES THE ASSESSMENT SHOW?

Fraud readiness at a glance

55.5	Developing	10	92.50	18.60
READINESS SCORE OUT OF 100	MATURITY BAND	DOMAINS ASSESSED	STRONGEST DOMAIN	WEAKEST DOMAIN
			Finance, banking & financial reporting	Digital, cyber-enabled & identity fraud

The review asked about 106 fraud schemes that apply to the organisation. For 46, every control that stops the scheme was reported in place. 58 have at least one such control reported as a gap. 1 relies on a control reported in place whose own supporting practices were reported as gaps. The figures above are test fixtures for this fictional demonstration, not an approved score.

Domain readiness profile



Ordered weakest first. Overall readiness 55.5 / 100.

WHY DOES THE POSITION LOOK LIKE THIS?

What is driving the position

PATTERN	ASSESSMENT SIGNALS	WHY IT MATTERS
Third parties and supply chain: 6 first-priority schemes open	New supplier process **Partly** Familiar caller still verified **Not in place** Change confirmed with supplier **Partly**	Fictitious suppliers enter through onboarding that can be skipped. The same area also leaves open: supplier payments are diverted through changed bank details and a supplier is set up with an account it does not own.
People, payroll and insider risk: 5 first-priority schemes open	Bank changes confirmed with employee **Not in place** Payroll reviewed by another person **Partly** Leavers removed before next run **Partly**	Salary redirection through fake bank change requests is common and fast. The same area also leaves open: ghost employees are paid and leavers stay on the payroll.
Digital, cyber-enabled and identity fraud: 5 first-priority schemes open	Multi-factor on all email **Not in place** Email never enough on its own **Not in place** Verification for calls, voice notes and video **Partly**	Most business email compromise starts with an account that has no multi-factor authentication. The same area also leaves open: a payment instruction received by email is acted on and a cloned voice or video instruction is obeyed.
Code accessible to staff: reported in place, not supported by its practices	Code accessible to staff **In place** Training on joining **Partly**	It is relied on to stop the scheme where staff do not know or understand what is expected. One self-reported answer says it is in place; the answers about the practices it depends on say otherwise.

> **THE PATTERN THAT MATTERS**
>
> Of 32 controls reported fully in place that the method can cross-check, 5 were cross-checked with one further self-reported answer about a practice they depend on: 5 consistent. The other 27 were not cross-checked and nothing is concluded about them. These cross-checks compare the organisation's own answers; they are not tests of operation and they change no figure.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

WHERE DOES FRAUD EXPOSURE MATTER MOST?

Priority fraud schemes

#	PRIORITY EXPOSURE	ASSESSMENT BASIS	POTENTIAL CONSEQUENCE	INTERRUPTION POINT	PRIORITY ORDER
1	**Invoices are paid for goods or services not received or not agreed** Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid.	Three-way match **Not in place** Quantities checked **Not in place** Services confirmed **Not in place**	Funds paid to a diverted, fictitious or overbilling supplier, often unrecoverable once released.	Every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first.	**Priority 1** First-priority scheme; 5 of the 5 controls answered are gaps.
2	**Supplier payments are diverted through changed bank details** Changed supplier bank details are the most common route for payment fraud, and cloned voices now defeat call-backs that rely on recognition.	Familiar caller still verified **Not in place** Change confirmed with supplier **Partly**	Funds paid to a diverted, fictitious or overbilling supplier, often unrecoverable once released.	The procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why.	**Priority 2** First-priority scheme; 2 of the 2 controls answered are gaps.
3	**Salaries are redirected through a fake bank change** Salary redirection through fake bank change requests is common and fast.	Bank changes confirmed with employee **Not in place**	Salaries paid to fictitious, departed or overpaid employees, recurring every pay run until found.	Every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect.	**Priority 3** First-priority scheme; 1 of the 1 controls answered is a gap.
4	**A payment instruction received by email is acted on** Acting on payment instructions received by email is how business email compromise succeeds.	Email never enough on its own **Not in place**	Payments, credit or goods released to someone impersonating a supplier, customer, employee or executive.	Put in place: email never enough on its own.	**Priority 4** First-priority scheme; 1 of the 1 controls answered is a gap.

Ordered by the draft method's scheme priority and the number of controls reported as gaps. The order indicates where to act first; it is not a risk rating.

HOW COULD THAT EXPOSURE MATERIALISE?

How the schemes would work here

Invoices are paid for goods or services not received or not agreed

Overbilling, fictitious deliveries or inflated rates are paid › Three-way match not in place; quantities checked not in place › Unauthorised commitments and approval override

Overbilling, fictitious deliveries or inflated rates are paid. Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid. Here, invoices are paid without being checked against what was approved or received; quantities checked: not in place.

Interrupted by: Until the design operates, the process owner checks every new case and the recent ones by hand against this standard: every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first.

Warning signs: Unauthorised commitments and approval override · Duplicate or false invoices · Overpricing, overbilling and inflated variations

Supplier payments are diverted through changed bank details

Supplier payments are diverted through changed bank details › Familiar caller still verified not in place; change confirmed with supplier partly › Payment redirection through false bank details or impersonation

A fraudster, often impersonating the supplier by email, voice or video, has the bank account changed. Changed supplier bank details are the most common route for payment fraud, and cloned voices now defeat call-backs that rely on recognition. Here, a follow-up call from the 'supplier' is accepted as confirmation; changes are confirmed, but sometimes using contact details taken from the request itself.

Interrupted by: Until the design operates, the process owner checks every new case and the recent ones by hand against this standard: the procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why.

Warning signs: Payment redirection through false bank details or impersonation

Salaries are redirected through a fake bank change

A request that appears to come from an employee changes where their salary is paid › Bank changes confirmed with employee not in place › Salary redirection through changed bank details

A request that appears to come from an employee changes where their salary is paid. Salary redirection through fake bank change requests is common and fast. Here, bank detail changes are made as requested.

Interrupted by: Until the design operates, the process owner checks every new case and the recent ones by hand against this standard: every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect.

Warning signs: Salary redirection through changed bank details · Ghost or fictitious employees and payees · Unauthorised pay increases, allowances or deductions

These are plausible schemes for an organisation with the controls it reported. They are not allegations that these events have occurred.

WHAT DOES MANAGEMENT NEED TO CHANGE?

What management should change

#	MANAGEMENT OUTCOME	WHY NOW	ACCOUNTABLE	WHAT GOOD LOOKS LIKE
1	**Three-way match, quantities checked and services confirmed**	Stops the scheme where invoices are paid for goods or services not received or not agreed. 5 of its controls are gaps today.	Head of procurement or CFO, with the creditors manager or financial controller	Every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first. Every purchase is approved by someone with the authority to do so before the organisation commits, and the approval is recorded.
2	**Familiar caller still verified and change confirmed with supplier**	Stops the scheme where supplier payments are diverted through changed bank details. 2 of its controls are gaps today.	Head of procurement or CFO, with the creditors manager	The procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why. Every change is confirmed with the supplier using contact details already on file before it takes effect.
3	**Bank changes confirmed with employee**	Stops the scheme where salaries are redirected through a fake bank change. Its control is a gap today.	HR or payroll manager, with the payroll manager	Every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect.
4	**Email never enough on its own**	Stops the scheme where a payment instruction received by email is acted on. Its control is a gap today.	Head of IT or IT provider	An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.
5	**Confirm the 1 other unsupported controls**	1 further control is reported in place while practices it relies on were reported as gaps.	Each process owner named in the supporting register	Every control relied on to stop a first-priority scheme is supported by the practices it depends on, confirmed by the person who runs it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

WHAT SHOULD HAPPEN IN THE FIRST 90 DAYS?

The first 90 days

30 days: Contain and complete the picture

0–30 DAYS

Owners are named and the most exposed schemes are contained.

Name one accountable executive for each area with first-priority schemes open or unsupported: procurement and third parties (6), people and payroll (5), digital and identity (5), customers and revenue (4) and cash, stock and assets (2).

CEO or company secretary

A signed list of schemes, their accountable executives and target dates.

Complete when: Every first-priority scheme has a named executive and a date.

Close the scheme where supplier payments are diverted through changed bank details: put in place familiar caller still verified and change confirmed with supplier.

Creditors manager

The procedure wording, training material on cloned voices, simulation or test results.

Complete when: Management's own records show, for every case in the period: the procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why.

Close the scheme where one person can order and approve payment: put in place orderer is not payment approver.

Head of procurement or CFO

The delegation of authority, system access lists, a sample of orders and the related payment approvals.

Complete when: Management's own records show, for every case in the period: the duties are always separated, or any exception is approved and recorded.

60 days: Close the first-priority gaps

31–60 DAYS

The controls that stop the first-priority schemes operate for every case.

Close the scheme where a fictitious supplier is created and paid: put in place new supplier process, directors compared with staff, dormant suppliers deactivated and suppliers re-checked.

Procurement or creditors manager

The onboarding procedure, completed onboarding files for a sample of new suppliers, exception reports.

Complete when: Management's own records show, for every case in the period: every new supplier goes through a defined process, with set checks and an approval, before it can be paid.

Close the scheme where a supplier is set up with an account it does not own: put in place bank account verified.

Procurement or creditors manager

Account verification results, for example through a bank's account verification service, and the onboarding checklist.

Complete when: Management's own records show, for every case in the period: every new supplier's account is verified through a bank or third-party service before the first payment.

90 days: Extend and embed

61–90 DAYS

Second-priority schemes are addressed and the scheme status is reported each month.

Confirm with HR lead or ethics officer how code accessible to staff operates and put in place training on joining.

HR lead or ethics officer

HR lead or ethics officer confirms in writing that the controls operate for every case.

Complete when: Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join?

Have the board or its audit committee receive the status of the 22 first-priority schemes each month until they are closed.

CEO or company secretary

The first monthly scheme status.

Complete when: Three monthly scheme status reports received and minuted.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

HOW WILL MANAGEMENT KNOW WHETHER READINESS IS IMPROVING?

What to check at the 90-day point

MEASURE	POSITION TODAY	90-DAY EXPECTATION
Three-way match	Invoices are paid without being checked against what was approved or received.	Every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first.
Familiar caller still verified	A follow-up call from the 'supplier' is accepted as confirmation.	The procedure requires a call back on the number on file regardless of any incoming call or video, and staff know why.
Bank changes confirmed with employee	Bank detail changes are made as requested.	Every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect.
Email never enough on its own	Payment changes received by email are acted on as received.	An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.
Controls reported in place but unsupported	1 of the controls reported in place.	Each confirmed by its process owner, with its practices in place.

Management conclusion

Fictional Retail Group (mixed controls) is not starting from zero: 46 schemes have every control that stops them reported in place. The work is concentrated. 22 first-priority schemes, most of them in procurement and third parties, people and payroll and digital and identity, need the specific controls named in this report, owned by the people the method names for them. Management should also not rely on the control reported in place whose own practices were reported as gaps until its owner confirms how it works.

This report is based on the organisation's own answers to the MK Fraud Readiness review, given by the respondent and the accountable functions named in it, and read against the draft review method, which MK has not yet approved. MK has not independently tested whether controls operate in practice, and no evidence was reviewed; evidence review is a separate Advisory service. TEST FIXTURE: hypothetical research value (scoring-frame simulation, Option A, midpoint, equal areas, no caps). Not an approved score, band or rating.